Critical Infrastructure Security

IY5612 (IY3612/IY4612) — Academic Year 2025/2026 (Unit 2)

Stephen D. Wolthusen
stephen.wolthusen@rhul.ac.uk

Department of Information Security and Communication Technology
Norwegian University of Science and Technology, Norway

and

Department of Information Security
Royal Holloway, University of London, United Kingdom

Unit 2— APT Case Studies

Contents

Complex Attacks

APT Case Studies

APT Case Studies
- Introduction
- Aurora
- APT1
- RSA
- A Perfect Storm
- Regin
- Triangulation
- APT28 and APT29
- Other APTs

Part II

APT Case Studies

APT Case Studies

In this block we cover selected APT case studies:

- Early Examples: Solar Sunrise, Moonlight Maze, Titan Rain
- Aurora, APT1 and Professional Groups
- The Regin toolkit and Operation Triangulation

Introduction
Aurora
APT1
RSA
A Perfect Storm
Regin
Triangulation
APT28 and APT29
Other APTs

Recommended Reading (1)

- Mandiant (FireEye):
  APT1: Exposing One of China's Cyber Espionage Units
  February 2013
- Kaspersky Labs:
  The Regin Platform: Nation-State Ownage of GSM Networks
  November 2014
- A. Michael:
  Cyber Probing: The Politicisation of Virtual Attack
  Defence Academy of the United Kingdom, October 2010
- J.R. Lindsay:
  Tipping the scales: The attribution problem and the feasibility of deterrence against cyberattack
  Journal of Cyber Security **1**(1), pp.57–67 (Nov. 2015)

Recommended Reading (2)

- FireEye:
  APT28: A Window into Russia's Cyber Espionage Operations
  October 2014
- FireEye:
  Hammertoss: Stealthy Tactics Define a Russian Cyber Threat Group
  July 2015
- European Union Institute for Security Studies: Hacks, Leaks, and Disruptions: Russian Cyber Strategies October 2018
- J. Bateman: Russia's Wartime Cyber Operations in Ukraine: Military Impacts, Influences, and Implications. Carnegie Endowment for International Peace, December 2022

Recommended Reading (3)

- B. Larin, L. Bezvershenko, G. Kucherin: Operation Triangulation: The Last (Hardware) Mystery. Kaspersky Labs, 2023

Introduction

Originally Advanced Persistent Threats (APT) were intended as a way to describe **State-Sponsored Espionage**

- Specifically, U.S. government was using this as a thinly-veiled synonym for one nation in particular

The methods and techniques described are now used by different entities in addition

- (Organised) crime
- Activists (criminal, nationalist, terrorist)

with substantial resources at hand allowing the construction of tool sets and persecution of longer campaigns

As of late 2024, espionage (corporate and governmental – see “Sunburst”) still appears dominant, but blackmail, sabotage, and support of kinetic operations (including “staging”) have also become routine – sometimes as a form of “re-use” (cf. NotPetya) or collateral damage

Defining APTs

Definition (*Advanced Persistent Threat*)

An adversary that possesses sophisticated levels of expertise and significant resources which allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g., cyber, physical, and deception). These objectives typically include establishing and extending footholds within the information technology infrastructure of the targeted organizations for purposes of exfiltrating information, undermining or impeding critical aspects of a mission, program, or organization; or positioning itself to carry out these objectives in the future. The advanced persistent threat: (i) pursues its objectives repeatedly over an extended period of time; (ii) adapts to defenders' efforts to resist it; and (iii) is determined to maintain the level of interaction needed to execute its objectives. *(U.S. NIST SP 800-39)*

Early Days: Solar Sunrise

From False Alarms. . .

A sequence of attacks on systems belonging to a number of U.S. defence agencies, the Lawrence Livermore National Laboratory, several Israeli Defence Force systems including deployment of packet analysers and Trojans was detected in late 1998

- This was thought to be the work of state-sponsored Iraqi attackers, mobilising resources from FBI, Air Force Office of Special Investigations, U.S. Department of Justice, the Defense Information Systems Agency, NSA, and CIA, given the code-name **Solar Sunrise**

This confirmed results from a NSA Red Team exercise in 1997 (**Eligible Receiver 97**) that was able to infiltrate and take over defence and national critical infrastructure systems

Early Days: Solar Sunrise

From False Alarms...

A sequence of attacks on systems belonging to a number of U.S. defence agencies, the Lawrence Livermore National Laboratory, several Israeli Defence Force systems including deployment of packet analysers and Trojans was detected in late 1998

- This was thought to be the work of state-sponsored Iraqi attackers, mobilising resources from FBI, Air Force Office of Special Investigations, U.S. Department of Justice, the Defense Information Systems Agency, NSA, and CIA, given the code-name **Solar Sunrise**
- The origin of the attack turned out to be a group of three teenage recreational hackers

This confirmed results from a NSA Red Team exercise in 1997 (**Eligible Receiver 97**) that was able to infiltrate and take over defence and national critical infrastructure systems

Early Days: Moonlight Maze

. . . via Early Espionage . . .

While not detected until 1999 when the penetration of U.S. Department of Defense satellite control systems was detected, this campaign (code-named **Moonlight Maze**) had lasted for more than two years

- Various classified and unclassified defence systems were penetrated
- Maps, troop configurations and deployments, military hardware designs were included in the compromised data sets
- Other systems penetrated included U.S. Department of Energy and military contractor systems
- Attackers also installed back doors in compromised systems

Attacks were traced to hosts controlled by the Russian Academy of Sciences, but this is likely to just have been a set of staging proxies

- The initial attribution to Russian state-sponsored attackers could not be maintained

Early Days: Titan Rain (1)

. . . via Early Espionage . . .

A number of incursions against U.S. Department of Defense systems (and later also other governments including UK and German systems were detected in 2003, but which may have been ongoing for some time before

- This set of operations was code-named **Titan Rain** by U.S. investigators and traced to Chinese systems
- Some information was released to the press in 2005 whilst briefing on Chinese PLA Computer Network Operations
- Targets again also included defence contractors including Lockheed Martin and national laboratories including Sandia National Laboratories, although obtaining mainly unclassified material

Early Days: Titan Rain (2)

. . . via Early Espionage . . .

Operators were careful to stage exfiltrated information via multiple intermediate systems in other countries

- A number of such traces could be back-tracked to a small number of networks in mainland China — but this does **not** constitute a meaningful attribution

Other campaigns from this period include **Sykipot** — identified in 2006, but active in 2011

- U.S. and UK systems in sectors including defence, IT, telecommunications, energy, and chemical/pharmaceutical industry were been targeted
- The usual combination of spear-phishing, zero-day attacks, and remote administration tools. . .

Another campaign detected in 2009 was **GhostNet**; this seems to have targeted diplomatic systems in a number of countries

- Modus operandi was similar, with a remote administration tool Gh0st RAT deployed

The Aurora Campaign

Google and more than 20 companies mainly in the US and Canada were targeted by attacks using the Hydraq or **Aurora** Trojan horse for a number of years

- The campaign was notable because of its use of a number of high-value zero-day attacks against Adobe Flash Player, Microsoft Internet Explorer, and XML Core Services

The attack against Google relied on an Internet Explorer memory corruption vulnerability (CVE-2010-0249)

- When these became known, the same framework was used to exploit a number of other vulnerabilities
  - This type of re-use often helps in attribution, even if it is only circumstantial
- The Aurora campaign utilised a common pattern for attacks, the **watering hole attack**

Watering Hole Attacks

Watering hole attacks rely on knowledge or anticipation of a targeted user accessing a web site, directly or relying on embedded code such as from an advertising (malvertising) system

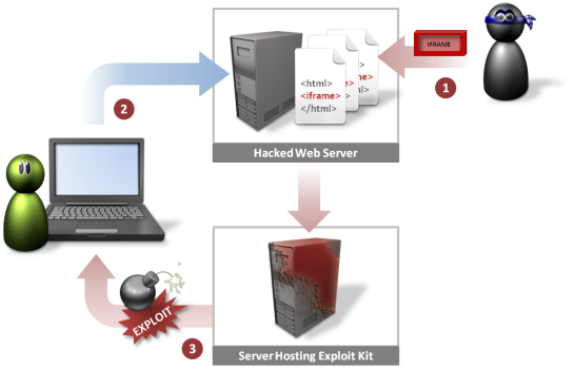
- This can be a known behavioural pattern, or an induced behaviour such as by sending a link

Depending on the exploit code available, the attacker must inject code (including embedded code such as Flash advertisements), or simply documents (e.g. for PDF, Microsoft Office documents)

- Attack construction appeared to be partly automated with tool support for creating exploit documents
- This tool support plus a shared C2 architecture allows tracing back multiple attacks to a likely single entity despite obfuscated code. . .

The Aurora Campaign

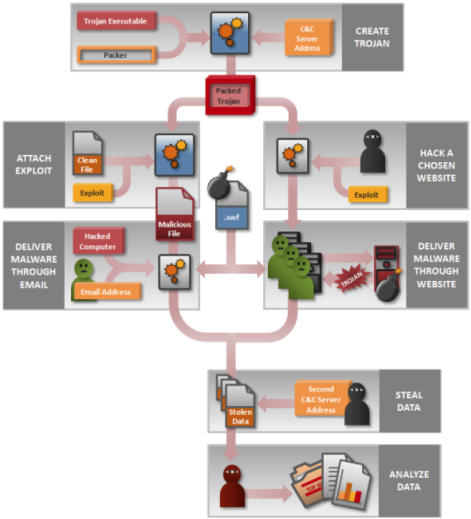
Watering Hole Attack



Steps in Attack

1. Attacker hacks legitimate Web server and injects IFRAME into Web pages
2. User browses to legitimate Web site
3. Returned Web pages contain IFRAME pointing to server hosting exploit kit

The Aurora Campaign
The Elderwood Platform



(Source: Symantec)

The APT1 Group

A number of groups of attackers can be identified in a similar way to the Elderwood group; one of these was called the APT1 group by Mandiant (now FireEye), claiming to link it to the PRC PLA Unit 61398

- A report on this was released in February 2013
- A number of attacks (141 between 2006 and 2013) were traced to APT1, with the longest undiscovered presence being 4 years and 10 months and an average of ≈1 year
- Usual pattern of operation was to continue exfiltration of data as long as access was maintained
- Area of interest is wide-ranging including product R&D, business plans and negotiations, manufacturing process information, general high-level employee communication and credentials, and also network intelligence

The APT1 Group

A number of groups of attackers can be identified in a similar way to the Elderwood group; one of these was called the APT1 group by Mandiant (now FireEye), claiming to link it to the PRC PLA Unit 61398

- A report on this was released in February 2013
- A number of attacks (141 between 2006 and 2013) were traced to APT1, with the longest undiscovered presence being 4 years and 10 months and an average of ≈1 year

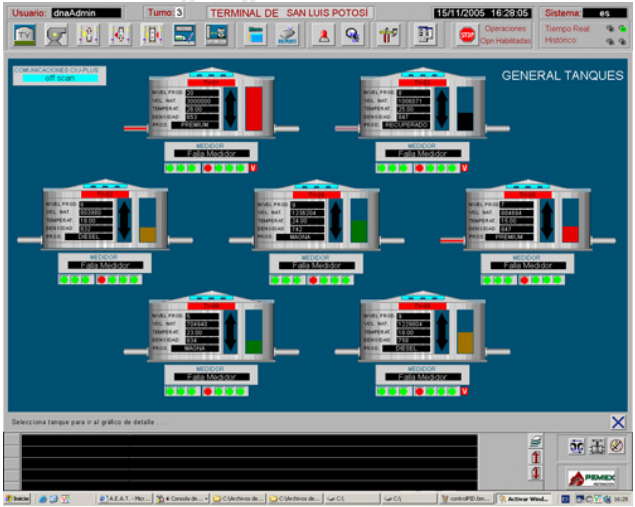
Good (sort-of) news:

As of late 2023, the average dwell time for APTs has been reduced substantially – but is still around 90 days with extreme outliers

- Usual pattern of operation was to continue exfiltration of data as long as access was maintained
- Area of interest is wide-ranging including product R&D, business plans and negotiations, manufacturing process information, general high-level employee communication and credentials, and also network intelligence

The APT1 Group
Selected Attacks

One such group of targets was a Canadian subsidiary (Telvent) of Schneider Electric, a manufacturer of SCADA equipment and specifically of interface and connectivity components for smart grid systems



(Source: Schneider Electric)

The APT1 Group
Selected Attacks

As seen before, spear-phishing forms a standard part of operating procedures, typically with the aim of running an exploit leading to the installation of a simple backdoor

- APT1 commonly deployed “beachhead” backdoors on initial targets forming part of a standard toolkit that was in development for years
- A backdoor feature led to the “**Comment Crew**” nickname
- Interestingly, the first iteration of the “WEBC2” toolkit dates to 2004, with continuous development over many years

WEBC2 is a simple backdoor connecting to a C2 server and trying to read covert tags (or comments) from an HTML page to obtain C2 commands featuring

- Execution/modification of code, upload/download of files, process management, keyboard and mouse sniffing, screenshots, and direct shell access or remote desktop

The APT1 Group
Selected Attacks

Similar backdoors used by APT1 used not only HTML traffic but also mimicked other legitimate communication protocols:

- MSN Messenger and Jabber/XMPP chat protocols
- GMail calendar

These protocols are commonly available for external contacts, and were additionally protected with TLS/SSL transport layer encryption

Beyond securing a beachhead, privilege escalation via exploits or breaking authentication (password) systems is a common step

- APT1 used a number of password dumping and cracking mechanisms as well as the common **pass-the-hash** transitive vulnerability

With the right privileges, internal reconnaissance can be carried out, followed by lateral movement to other systems and segments

The APT1 Group
Selected Attacks

Securing footholds on multiple systems also serves as a backup in case access to an initial victim is lost

For exfiltrating information and C2 contact, an important objective is to secure legitimate users' VPN credentials (e.g. for home office work)

Similarly, once credentials are secured, web portals and cloud applications can be accessed and data harvested

- Harvesting and other C2 tasks can occur through compromised intermediate systems
- For interactive sessions such as RDP, a sequence of proxies can be used for obfuscation purposes

Password Generator Tokens

SecurID Token with PIN Pad

Not-So SecurID (1)

On 3 March 2011, two separate emails were sent to a small group of employees of RSA (a subsidiary of EMC), one of which simply read

I forward this file to you for review. Please open and view it.

The file had a spreadsheet as an attachment ("2011 Recruitment plan.xls"), and at least one of the employees **retrieved this from his junk folder**

- The spreadsheet contained a zero-day vulnerability (CVE-2011-0609) that relied on an embedded .swf (Adobe Flash) file in the Microsoft Excel document
- CVE-2011-0609 was interesting as it was a "cross-platform" vulnerability in Adobe Flash Player 10.2.154.13 and earlier (Windows, MacOS, Linux, Solaris, Android)

Not-So SecurID (2)

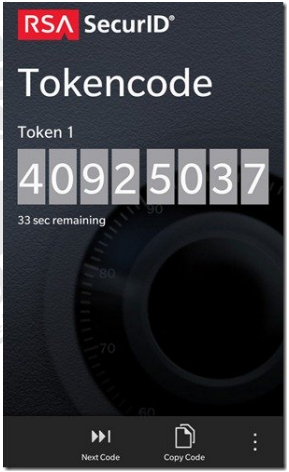
The attack proceeded to install a **remote administration tool**

- This aspect was even less novel, relying on a variant of a “Poison Ivy” backdoor Trojan (Remote Administration Tool, RAT) that had been modified to reverse connect
  - The tool had been around for a long time, and was e.g. used in a large-scale attack (“Operation Aurora”) against Google in 2009
- Poison Ivy is quite primitive but small (≈10kB), but can modify processes and services, network connections, Registry database, devices, and list of installed applications as well as up- and download files and general shell functionality
- The attackers proceeded to collect information, aggregated it, and sent it to an external web site, erasing evidence afterwards

Not-So SecurID (3)

Information exfiltrated from RSA allowed cloning of SecurID tokens

- Authentication devices come in different flavours for multi-factor authentication
- Shared secret and synchronised time-base, possibly coupled with PIN entry device
- Devices come in different form factors, including so-called *soft tokens*
- Long-standing, widespread use – more than 40m hardware, up to 250m software-based tokens



Not-So SecurID (4)

The breach at RSA was described as an APT, but was neither particularly "A" nor "P", except for targeting and the zero-day exploit used

- A parallel effort seems to have targeted government agencies, defence contractors from the same event, linked to a longer-standing intelligence operation identified publicly by McAfee (**Shady RAT**)

More interestingly, the alleged state-sponsored attackers then used the information from RSA to penetrate VPN systems of several defence contractors, including Lockheed Martin, Northrop Grumman, and L-3 Communications in March/April 2011

This may fit the "A" part of "APT" somewhat better — but note that each stage is not necessarily very sophisticated, just the operational planning

Not-So SecurID (4)

The breach at RSA was described as an APT, but was neither particularly "A" nor "P", except for targeting and the zero-day exploit used

- A parallel effort seems to have targeted government agencies, defence contractors from the same event, linked to a longer-standing intelligence operation identified publicly by McAfee (**Shady RAT**)

More interestingly, the alleged state-sponsored attackers then used the information from RSA to penetrate VPN systems of several defence contractors, including Lockheed Martin, Northrop Grumman, and L-3 Communications in March/April 2011

This may fit the "A" part of "APT" somewhat better — but note that each stage is not necessarily very sophisticated, just the operational planning

Trickle-Down Effects

Supply chain attacks became more prevalent from 2017, e.g. targeting comercial software (e.g. NetSarang/ShadowPad, Avast CCleaner)

A Perfect Storm(-0558)

In May 2023 a US agency noticed unusual access patterns to Microsoft 365 email audit logs showing unusual `ClientAppID` and `AppID` entities

- This would occur when legitimate clients access Exchange Online (M365) accounts through custom protocols and applications, which was not the case
- The attacker had managed to not just compromise individual accounts as expected, but **much** worse
- In a multi-step attack, the threat actors obtained an inactive Microsoft Account consumer signing key that had been inactive since 2021 – normally used to generate authentication tokens for personal Microsoft accounts (MSAs)
- Microsoft did *not* validate inactive account keys or issuer, allowing the attacker to sign access requests; this could have been spotted but was not

APT Case Studies
Introduction
Aurora
APT1
RSA
27 A Perfect Storm
Regin
Triangulation
APT28 and APT29
Other APTs

Leveraging Access

A flaw in the `GetAccessTokenForResource` API allowed access via the fraudulent access tokens, which could then be leveraged for obtaining Exchange Online tokens as well as **Azure AD** tokens

- Azure AD is used across the entire Microsoft ecosystem (Azure, SharePoint, Teams, OneDrive, and third-party applications using Microsoft as an OpenID identity provider ("login with Microsoft")

In July 2023 Microsoft blocked old tokens, invalidated MSA keys prior to the detection of the incident, an extension to OpenID 2.0 for validation

- The information released by Microsoft understates the significance and depth of the vulnerability considerably
- Storm-0558 is tentatively believed to be a PRC threat actor

The Regin Espionage Kit

The Regin data collection tool was developed and deployed over a number of years, dating to at least 2008

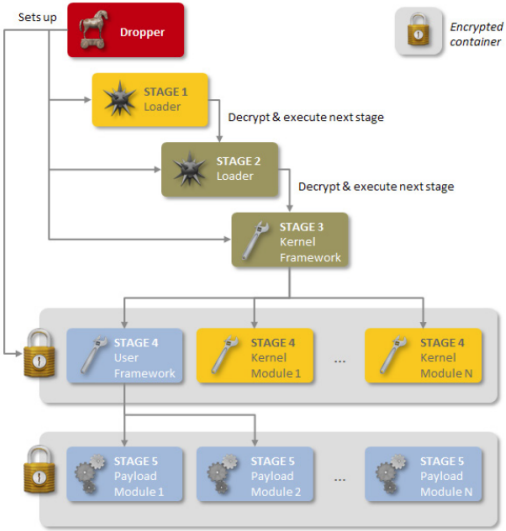
- Two distinct generations (2008–2011) and from 2013 were observed, but more may exist
- Regin infections were relatively promiscuous by country and sector

Regin is able to proceed from a small, simple **Dropper** and uses a multi-stage deployment framework where subsequent steps can be configured to match target requirements

- Only the initial stage loader/driver is visible, later stages are transmitted in encrypted form
- Encrypted components are stored in obfuscated regions (e.g. outside file system in raw sectors, in Windows Registry)

The Regin Espionage Kit

Multi-Stage Architecture



(Source: Kaspersky)

The Regin Espionage Kit

Multi-Stage Architecture

Stage 0 was not observed in the wild; Stage 1 masqueraded as a driver file, which seeks to load Stage 2 from NTFS extended attributes or Registry data

- Stage 2 is encrypted and, once decrypted and running as a kernel mode driver, will obfuscate the Stage 1 loader
- Stage 2 is very small, and its only task is to locate the encrypted Stage 3 kernel mode DLL (again outside regular file system), decrypt, and load

Stage 3 then configures the desired modules for Stage 4 and can locate where these will be retrieved from, respectively

- Stage 4 combines both user mode and kernel mode components, and loads the main payload from container files (encrypted virtual file system containers)

The Regin Espionage Kit
Payload Examples

Payload functionality is largely similar to other RATs:

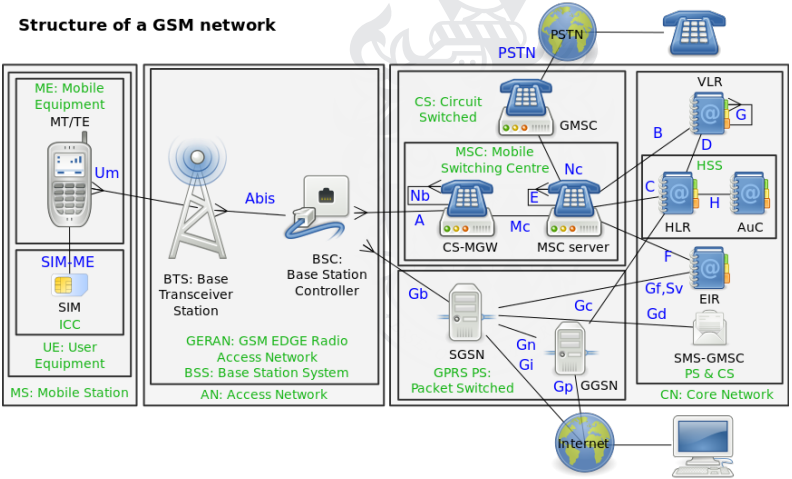
- Network sniffing
- Local system and network information
- File system crawling
- Keyboard and mouse sniffing and injection/RAT, screenshots
- Password and password database retrieval
- Sniffing GSM Base Station Controller (BSC) administration network traffic

C2 channels allowed multiple pathways including raw ICMP, UDP, TCP and HTTP traffic and can also be used to form peer-to-peer structures for lateral C2 forwarding

The Regin Espionage Kit

BSC Admin Network Manipulation Payload

A GSM network (UMTS/4G/5G will differ significantly) edge operates a number of base stations:



(Source: Kaspersky)

The Regin Espionage Kit

BSC Admin Network Manipulation Payload

Once it had penetrated a Base Station Controller (BSC), the matching Regin payload was able to manipulate and control the operation of Base Transceiver Stations (BTS)

- These are normally used to allocate radio resources to connections and to perform handovers among base stations
- Other functions allow management of base stations and individual radio resources

Regin was last seen to be active in late 2014

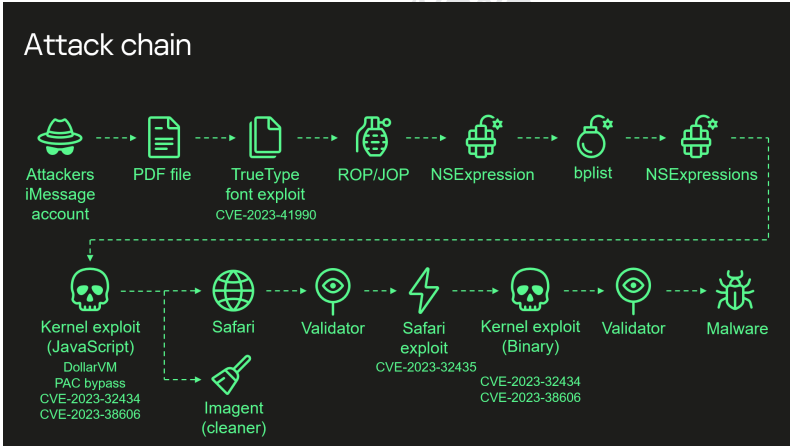
Operation Triangulation

A Few Rotten Apples

An (as of December 2024 unidentified) threat actor compromised the entire product range of iOS, iPadOS and MacOS devices (iPhone, Watch, TV, iPad, Mac) via a set of five zero-day vulnerabilities

- The attack was detected by Kaspersky's Russian operations, and the actor had apparently targeted Russian entities since at least 2021
- Payload delivery could occur over a number of different ways including the Pegasus and Graphite infrastructure, but could also occur via "zero click" iMessage messages that contained a PDF exploiting an ancient TrueType VM vulnerability going back to the 1990s
- Aside from using multiple zero-day attacks and fairly sophisticated detection avoidance and counter-forensics that were effective across all Apple operating systems, only selected endpoints are provided with the full retrieval suite

Triangulation
Attack Chain



(Source: Kaspersky)

Triangulation
Low Level Attack

No APT identifier has been assigned (despite the issue being detected in July 2023), but the attack has the hallmarks of a well-resourced adversary

- The attack used the CVE-2023-38606 vulnerability acting as a bypass for security mechanisms in Apple SoCs protecting kernel memory access (Page Protection Layer)
- Memory-mapped I/O (MMIO) has legitimate uses, but the Apple SoC have a feature (unclear if for debug purposes or otherwise) in the GPU used nowhere else in Apple's code or firmware allowing custom MMIO to access the entire memory of the system including kernel memory without restrictions

APT 28 (“Fancy Bear”, “Sandworm”, or “Tsar Team”)

The group identified as APT28 appears to have been operational for over a decade

- As with many professionalised groups, tools and techniques have been maintained and enhanced over many years
- Analyses of malware indicate a larger group based on advanced software engineering methodology employed
- Interestingly enough, the group also seems to largely keep to regular office hours (Moscow time) based on compiler time-stamps
- Other circumstantial evidence is based on APT28 being active where interests of the Russian Federation are concerned (Russian “near abroad” such as Georgia’s Ministries of Defense and Internal Affairs
- Main claim to recent fame includes the 2015–16 attacks against Ukraine and collateral damage (NotPetya) from this
  - One recent Sandworm activity were large-scale attacks against the Republic of Georgia (2019)

APT 28 Methods and Targets

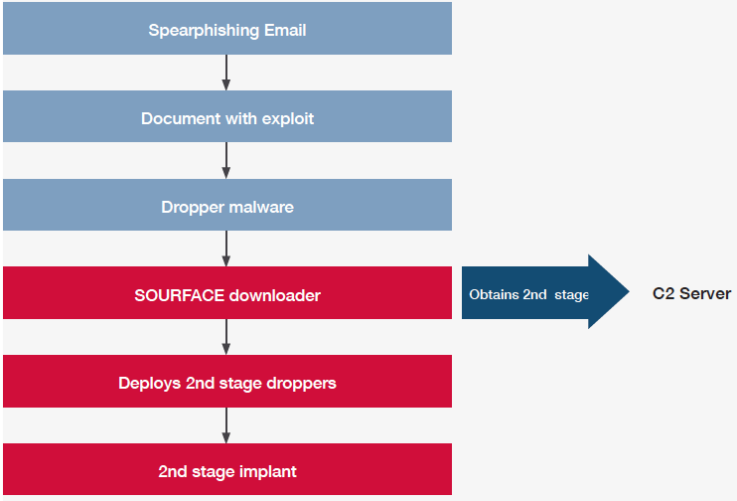
Further targets included governments, particularly from Eastern Europe (e.g. Ukraine, especially defence-related) but also other areas of interest to the Russian Federation (European Commission, German parliament NATO, OSCE, World Bank. . .)

- Many initial approaches rely on spear-phishing attacks, sometimes drawing on information that is not entirely public to make the approach more plausible

APT28 frequently relies on a framework containing a multi-stage downloader (Sourface or Sofacy) that is also linked to backdoors and rootkits as well as credential harvesters

- The architecture is modular and can be tailored with implants for specific objectives and victims
- Modules exhibit good quality (malware) techniques including counter-forensic features

APT 28 Work Flow



APT 28 Recent Activity

The APT28 report by FireEye dates from 2014, and does not include material on more recent events particularly targeting various nation state governments

- Overall approach is largely consistent relying substantially on spear-phishing emails, also using web-based email services, homonym domains, and obfuscated links to obtain subsequent credentials
- GRU Unit 74455 has also been linked to attacks against the 2016 US elections, attacks against critical infrastructure in Ukraine and Georgia in 2019, interference in French elections in 2017 and the 2018 Winter Olympics
- More recently this APT has been attempting to subvert Ukrainian and Ukraine-linked systems including critical national infrastructures

APT 29 (“Cozy Bear”)

A similar profile of targets is pursued by APT 29, which has also been seen operating as early as 2008 and has recently pursued targets in the US (DoD, US DNC, and a number of think tanks and non-government organisations)

- Techniques include again spear-phishing, but with a “signature” of using Twitter and steganographic messages as a communication channel, the Hammertoss remote access tool
- Encrypted and steganographically obfuscated traffic can then be exchanged via Twitter and other public services such as GitHub repositories
- Recent activities of APT29 include espionage efforts against COVID-19 vaccine research (2020) and the Sunburst espionage campaign (2020–2021)

. . . similar activities and tools are of course found “elsewhere” as well

A Surfeit of Bears

Different groups within the Russian state have overlapping capabilities, partly explained by affiliations:

- APT29 (“Cozy Bear”) is associated with the SVR (foreign intelligence service)
- APT28 is associated with the GRU (main directorate of the armed forces – intelligence), units 74455 and 26165
- “Energetic Bear” seems linked to the FSB (federal security service), unit 71330
- “Primitive Bear” is another FSB entity

Cyber crime groups based in Russia appear to have at least indirectly co-ordinated with state actors

- In at least on case (“Conti Group”) this led to an open split between Russian and Ukrainian criminals, resulting in the release of ransomware code, identities, and messages of Russian members

Reprise: NotPetya

Other attacks against Ukraine will be covered in more detail later in the context of cyber-physical systems; effectively Ukraine has been a “live fire zone” since the conflict between Ukraine and the Russian Federation escalated in 2014

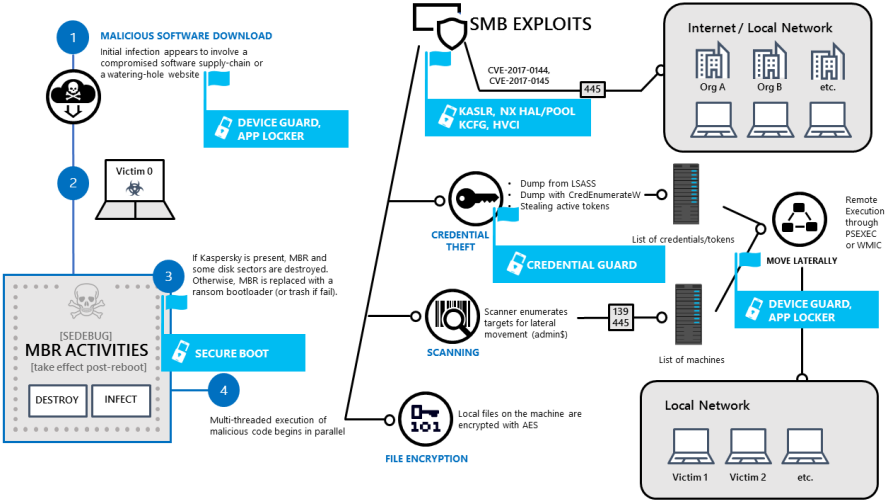
- The GRU unit 74455 (“Main Centre for Special Technologies”, GTsST) developed a variant of the Petya ransomware
- The malware relied on exploits (EternalBlue – MS17-010, EternalRomance) of the SMB protocol leaked from the US NSA’s databases and a Mimikatz credential stealing variant to propagate
- Its origin, however, was an implant in an accounting software widely used in Ukraine (M.E.Doc, developed by Linkos Group)
- While Petya (like WannaCry before) was a regular ransomware, NotPetya encrypted files and MFT without retaining the key; the ransom demand was only a decoy

Spreading NotPetya

In terms of technology, NotPetya was a derivative, pulling together exploits and propagation mechanisms previously also used by others

- Knowledge of the widespread use of the accounting software largely limited to Ukraine was key to the success — apparently meant to cause indiscriminate economic damage
- Victims were using mostly older Microsoft Windows machines with poor patching discipline and network segmentation
- The propagation mechanisms (PSEXEC, WMIC for stolen credentials via Mimikatz) and SMB exploits (CVE-2017-0144, CVE-2017-0145) made for very fast propagation both inside organisations (laterally) and across entities
- However, about 30% of NotPetya victims were **outside** Ukraine

NotPetya Propagation



Source: Microsoft

NotPetya Collateral Damage

While the Sunburst attack discussed earlier was active for several months without detection, raising questions about just how far back one has to go to recover backups, a key characteristic of NotPetya was **speed**

- Organisations hit by NotPetya would have had minutes before their (non-segmented) networks were saturated

In the case of Møller-Mærsk, a single user in an office in Odessa, Ukraine did have M.E.Doc installed; the global IT operations centre (based out of Maidenhead, Berks) could not deactivate systems in time

- Operating a flat topology across 574 offices in 130 countries did not help: The combination of EternalBlue with Mimikatz meant that only a few pre-Windows 10 legacy systems (including Windows 2000!) were required to allow harvesting of credentials and lateral movement
- This affected all freight bookings, port operations, loading, and even site access via key cards, affecting 20% of worldwide shipping capacity

Backups and the Ability to Restore

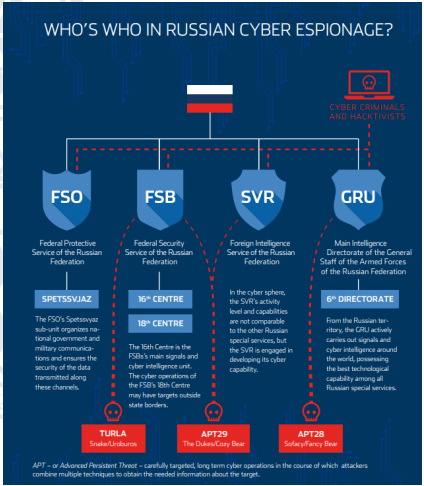
Ransomware attacks have been (only partially in jest) called tests of how well an organisation's backup and restore capability is functioning

- In the case of NotPetya, this was even more important
- Møller-Mærsk **did** have database and file system backups, but it appears that they had relied on Microsoft's Active Directory to replicate itself across the 150 domain controllers without keeping a "cold" or "warm" backup
  - Normally any DC can be used to re-populate the databases of all others, but this is not viable in case of corruption
- Møller-Mærsk was "lucky" since a power failure at its office in Accra, Ghana had meant **one** DC was offline at the time of attack
  - Network speeds were insufficient for a full recovery, so this had to be flown in via a "relay race" via Lagos, Nigeria as the staff in Ghana did not hold a UK visa
  - Step-wise recovery still took 2 weeks with improvisations including booking freight via WhatsApp and staff personal email

Rules

Espionage is an accepted tool of foreign policy — it becomes problematic when it shades into industrial espionage, sabotage, or similar outright damaging activities

- In one recent egregious instance, GRU Unit 74455 operators were indicted in October 2020 by the US DOJ for NotPetya (and other) activities
- Treating this as a criminal justice matter is not the only option



Source: Estonian Foreign Intelligence Service

Rules

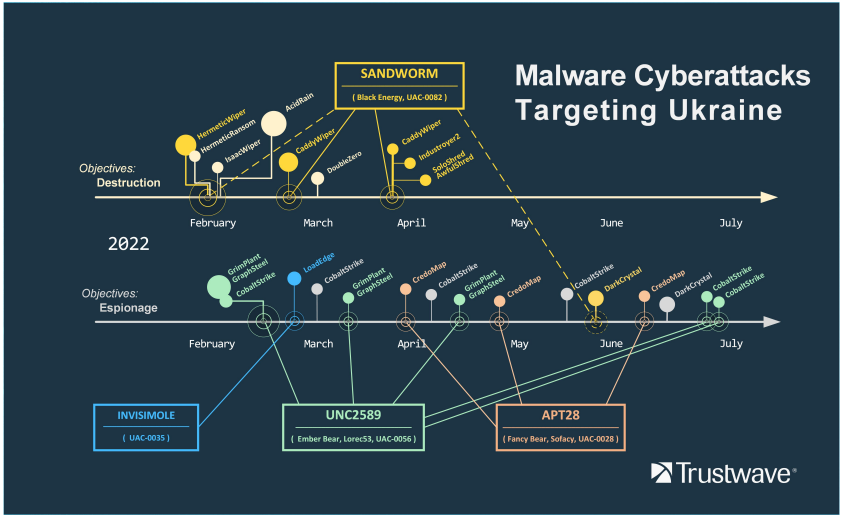
Espionage (in peacetime) is not explicitly addressed in international law, the Geneva Conventions regulate only treatment of spies during armed conflict

- **Coercive** operations would constitute an internationally wrongful act under the UN Charter Article 2(4) equivalent to armed attack
- This entitles the attacked nation to a proportionate (also military) response

Source: U.S. Department of Justice

Fast Forward to 2023 — 2025

Re-purposing Attacks



Source: TrustWave

Division of Labour

Among the *many* groups attributed to the Chinese government, a familiar division of labour is visible:

- The recent (2023-24) major breach of almost all US telcos ("Salt Typhoon") can be considered a classic counter-intelligence breach with a good helping of additional intelligence
- Other recent campaigns (e.g. "Volt Typhoon") were more keen to attack targets of opportunity and gain a foothold in various CNI systems
- This is part of a mature and complex setup of groups belonging to different units including semi-private entities, PLA-authorised forces (either with the MSS and MPS) and specialised military forces

Sloppy, Cocky, or False Flags?

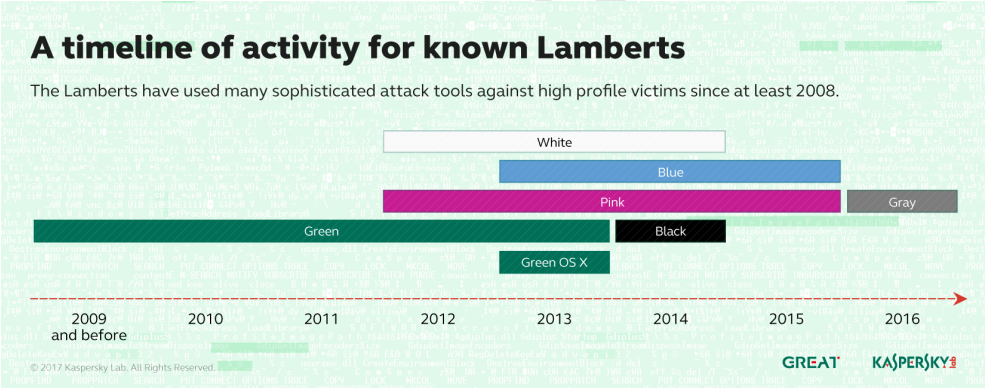
Consider the Longhorn / Lamberts APT (no number in Mandiant/FireEye's list)

- Active since 2008, with most activity in 2010-16
- Targets in 40+ countries, many in Middle East
- Family of Malware containing active (Black), passive (White) implants and staging (Blue, Green) components both for Microsoft Windows and Apple iOS
- Later components (Pink) contain beaconing functionality, and can orchestrate multi-platform malware, more recently also as user-space passive implants (Grey) with more in the wild

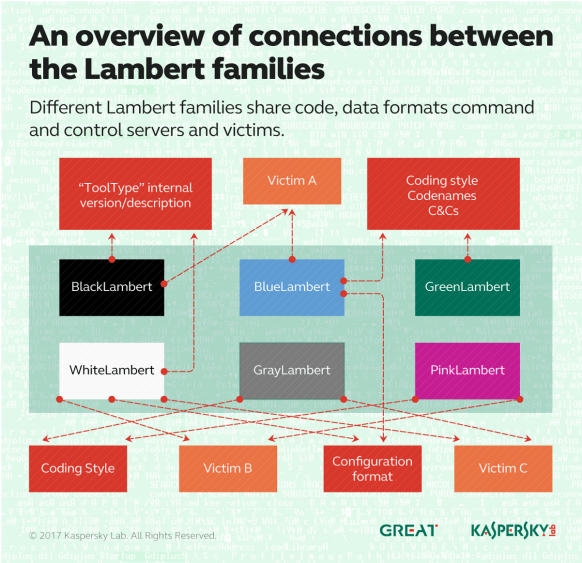
Code was cross-referenced to material contained in leaks from intelligence sources identifying a North American entity

- A number of coding mistakes and embedded codewords with cultural references would have suggested this
- As always, such evidence is subject to interpretation and may be a false flag operation

Longhorn/Lamberts



Longhorn/Lamberts



Longhorn/Lamberts

Use of language and particularly use of code words with cultural references rather than random codewords are indicative of likely origins:

```
.0041ED80:  00 00 00 02-00 00 00 73-7A 38 00 47-72 61 70 68    ☻   sz8 Graph
.0041ED90:  69 63 73 20-55 74 69 6C-69 74 79 20-4D 67 6D 74  ics Utility Mgmt
.0041EDA0:  20 53 65 72-76 69 63 65-00 2E 00 00-00 02 00 00   Service .   ☻
.0041EDB0:  00 32 6F 69-00 4D 61 6E-61 67 65 73-20 69 6E 74   2oi Manages int
.0041EDC0:  65 72 6E 61-6C 20 67 72-61 70 68 69-63 73 20 64  ernal graphics d
.0041EDD0:  72 69 76 65-72 73 00 12-00 00 00 02-00 00 00 66  rivers ↕   ☻   f
.0041EDE0:  69 64 00 50-49 5A 5A 41-00 14 00 00-00 02 00 00  id PIZZA ¶   ☻
.0041EDF0:  00 6F 75 31-00 41 53 53-41 55 4C 54-00 25 00 00   ou1 ASSAULT %
.0041EE00:  00 02 00 00-00 79 30 32-00 68 74 74-70 3A 2F 2F   ☻   y02 http://
.0041EE10:  77 77 77 2E-6D 69 63 72-6F 73 6F 66-74 2E 63 6F  www.microsoft.co
.0041EE20:  6D 00 3C 00-00 00 02 00-00 00 69 34-67 00 68 74  m <   ☻   i4g ht
.0041EE30:  74 70 73 3A-2F 2F 63 64-6E 2E 66 6D-6C 73 74 61  tps://cdn.fmlsta
.0041EE40:  74 69 63 2E-63 6F 6D 7C-68 74 74 70-73 3A 2F 2F  tic.com|https://
.0041EE50:  31 32 30 2E-35 30 2E 33-38 2E 31 38-37 00 16 00  120.50.38.187 ▬
.0041EE60:  00 00 02 00-00 00 70 73-75 00 6C 6F-67 69 6E 2E   ☻   psu login.
.0041EE70:  70 68 70 00-18 00 00 00-02 00 00 00-34 62 6B 00  php ↑   ☻   4bk
.0041EE80:  67 65 74 63-6F 6E 66 2E-70 68 70 00-18 00 00 00  getconf.php ↑
```

“Green Lambert” 3.0.5 (“PIZZA ASSAULT”) decrypted configuration block with code words

Supply Chains . . .

. . . Sometimes Work Both Ways

Supply chains figure prominently in many attacks, and kill chains do not need to start with the actual victim as seen in the RSA breach

Examples include the 2013–2014 U.S. Office of Personnel Management breach leaking millions of sensitive personnel records and background information used e.g. to assess security clearances as well as fingerprint data

- Attackers breached OPM in November 2013, exfiltrating information on IT system architecture and suppliers
- Subsequent attacks targeted two contractors (USIS and KeyPoint) with access to OPM servers

We will discuss supply chain attacks and further examples later on in the module — these often form a **network** of suppliers where an organisation has limited visibility of upstream suppliers

Other Actors

Inevitably, tools and capabilities as well as policy spread

- In recent years groups attributed to Iran (APT33, APT34, APT39) have been quite active — indicating a build-up of capabilities, even before more recent events
- Other highly active groups include Lazarus (attributed to the People's Republic of North Korea), although this actor is largely indistinguishable from organised crime groups, but APT43 seems more "traditional"
- Other APT have quite regional foci (e.g. Levante, Asia-Pacific, etc.)
- At least for APTs associated with nation states, targets change with strategic priorities, but clearly other nations are catching up
- Some countries do not need to develop native capabilities, "guns for hire" for lawful surveillance (e.g. Gamma Group, Hacking Team, and NSO) and other more or less mercenary entities can provide such capabilities

Summary

This section provided material on

- Early Examples: Solar Sunrise, Moonlight Maze, Titan Rain
- Aurora, APT1 and Professional Groups
- Complex Attacks, Collateral Damage, and the Risk of False Flags
- The Regin toolkit and Operation Triangulation